Tasks.md: Unauthenticated Path Traversal to Remote Code Execution

Researcher	Kashish Topiwala
Product	Tasks.md (self-hosted markdown kanban) - BaldissaraMatheus/Tasks.md
Affected	baldissaramatheus/tasks.md:latest (commit 8f43374); unpatched at HEAD
CWE	CWE-22 (Path Traversal) + CWE-306 (Missing Authentication)
CVSS 3.1	9.8 Critical - AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

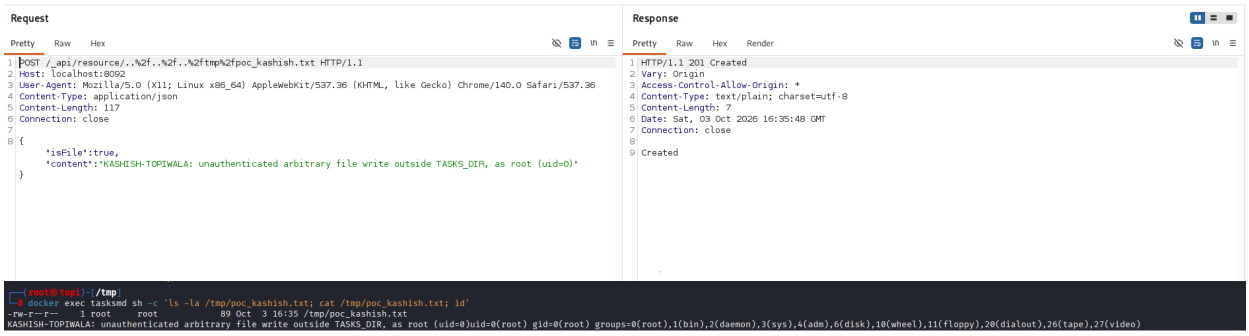
Summary

Tasks.md is a self-hosted markdown kanban board. The backend API has no authentication. The API uses the filename from the request to build a file path. It does not remove path traversal. An attacker can send a filename that contains ../ sequences. The server then writes the file outside its data directory. The server runs as the root user. The attacker can overwrite the server code and run commands as root.

Steps to reproduce

1. Send a POST request to /_api/resource/ with a path-traversal filename (for example ..%2f..%2f..%2ftmp%2fpoc.txt). Do not send any authentication.
2. Put {"isFile":true,"content":"..."} in the request body.
3. Read the response. The server returns HTTP 201. The file is written outside the data directory, as the root user.
4. To get code execution, send the same request with the filename ..%2f..%2fapi%2fserver.js and JavaScript content. The code runs as root when the server restarts.

Proof of Concept



Impact

- An unauthenticated attacker writes any file on the server, as the root user.
- An unauthenticated attacker reads any file on the server.
- An unauthenticated attacker deletes any file on the server.
- An attacker overwrites the server code and runs commands as root.

Remediation

- Remove path traversal from the filename. Reject ../ sequences and absolute paths.

- Check that the final path stays inside the data directory before you write, read, or delete.
- Add authentication to the API. Do not run the server as root.

References

- https://github.com/BaldissaraMatheus/Tasks.md/blob/main/backend/server.js
- https://cwe.mitre.org/data/definitions/22.html
- https://cwe.mitre.org/data/definitions/306.html